

Question 1:

Code injection is a cyberattack where an attacker inserts malicious code into a vulnerable application, exploiting poor data handling to trick the program into executing it, leading to data breaches, system compromise, or malware installation. It happens when applications process untrusted user input (*like forms, URLs, cookies*) as executable code, often due to a lack of input validation or sanitization, allowing attackers to control program flow and steal sensitive data or take over the system. Common types target databases (SQL Injection), operating systems (Command Injection), or other services, with prevention focusing on strict input validation, parameterized queries, and avoiding dynamic evaluation of user data.

Example: An attacker submits `os.system('rm -rf /')` as input in a form field, causing the system to execute the command and delete critical files, due to inadequate input sanitization.

➤ How it Works

- **Vulnerability:** An application uses unvalidated or unsanitized data from users (e.g., web forms, URL parameters) directly in its code or database queries.
- **Injection:** The attacker sends specially crafted input containing malicious code (in the application's language, like SQL, Python, PHP).
- **Execution:** The vulnerable application treats this input as legitimate code and executes it, often on the server.

➤ Consequences

1. Unauthorized data access, modification, or deletion.
2. Complete server takeover.
3. Installation of malware or ransomware (like WannaCry).
4. Reputational damage and financial loss.

➤ Prevention

Read the last page from the pdf

Question :02

SQL injection (SQLi) is a web security vulnerability that allows an attacker to interfere with the queries an application makes to its database. It occurs when untrusted user input is directly concatenated into dynamic SQL queries without proper validation or parameterization, allowing malicious SQL commands to be executed by the database engine.

Attackers exploit SQL injection vulnerabilities by entering malicious SQL code into input fields (like login forms, search bars, or URL parameters) which are then included in a database query. This can alter the original query's logic or structure to perform unintended actions.

Example: An attacker enters ' OR '1'='1 into a login form, manipulating the SQL query to bypass authentication and gain unauthorized access to the system.

➤ Impact

- **Data Breach:** Unauthorized retrieval of sensitive data like passwords, credit card numbers, and PII.
- **Data Manipulation:** Unauthorized modification or deletion of database records.
- **Privilege Escalation:** Gaining administrative or root access to the database or underlying server.

➤ Prevention :Same

